

TECHNOLOGY



Designing Microsoft Azure Infrastructure Solutions: AZ:305

Design Authorization



Learning Objectives

By the end of this lesson, you will be able to:

- Gain insights into the authorization process to grant permission to an authenticated person to perform an action or operation
- Identify Role-based access control (RBAC) elements to provide fine-grained access management of resources in Azure
- Trace Microsoft Entra Privileged Identity Management to minimize account privileges
- List the best practices of identity and access management to establish a single enterprise directory



Authorization Approach

Authorization

It is the act of granting permission to an authenticated person to perform an action or operation.



The Microsoft identity platform implements the OAuth (Open Authorization) 2.0 protocol for handling authorization.

OAuth (Open Authorization)

It allows internet users to grant websites or applications access to their information on other websites.



It is widely used by major companies like Amazon, Google, Facebook, Microsoft, and Twitter.



OpenID Connect

It is a cross-platform authentication system based on the OAuth 2.0 standard family.



It employs basic REST/JSON message flows to *make simple things simple while still making sophisticated things feasible.*



OpenID vs. OAuth

	OpenID	OAuth
Dates from	2005	2006
Current version	OpenID 2.0	OAuth 2.0
Main purpose	Single sign-on for consumers	API authorization between applications
Protocols used	XRDS and HTTPS	JSON and HTTPS
No. of related CVEs	24	3

Authorization: Use Cases

Delegating authentication and authorization to Entra ID enables scenarios such as:

01

Conditional access policies

02

Multi-factor authentication

03

Single sign-on

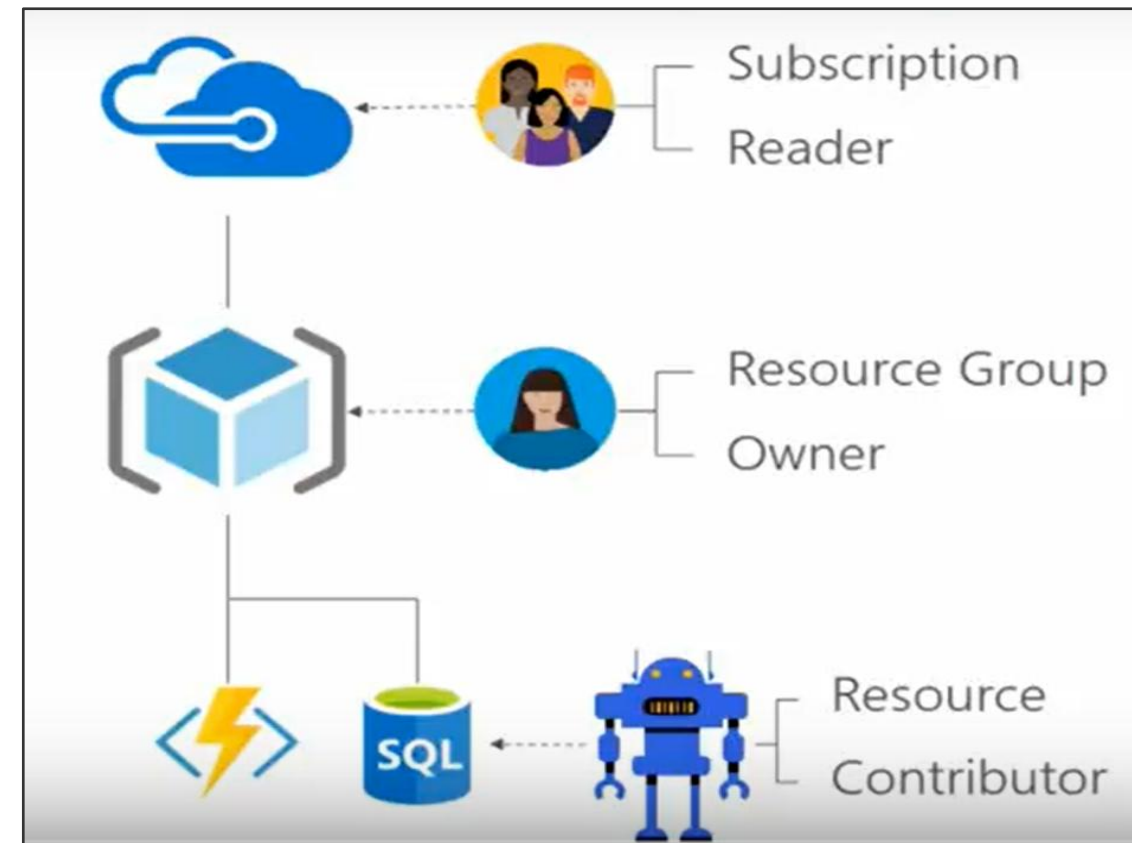


TECHNOLOGY

Access Management Solution

Role-Based Access Control (RBAC)

It is the capability to grant appropriate access to Entra ID users, groups, and services.



Role-Based Access Control

It provides fine-grained access management of resources in Azure.



- Is built on Azure Resource Manager
- Segregates duties within the team
- Grants access for what the users need

RBAC Elements

To create a role assignment, three elements are required, such as:

A security principal

A role definition

A scope

RBAC allows access control to the resource by assigning roles.

RBAC Elements

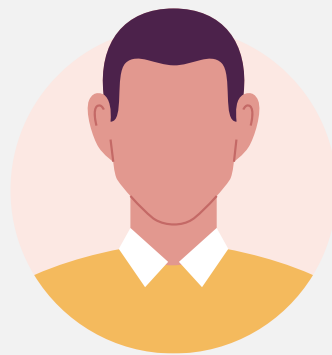
Concept	Definition
Security principal	Object that represents something that is requesting access to resources
Role definition	Collection of permissions that lists the operations that can be performed
Scope	Boundary for the level of access that is requested

- Users can assign access described in a role definition through assignments.
- Azure Blueprints and Azure Managed Apps set deny assignments, which are read-only and limit specific permissions.

Security Principal

It is a user, group, service principal, or managed identity that requests access to Azure resources.

Security principal



User



Group



Service
principal



Managed
identity

Role Definition

A role is a collection of actions that can be performed on Azure resources.

2 Role definition

Owner
Contributor
Reader
...
Backup Operator
Security Reader
User Access Administrator
Virtual Machine Contributor

Built-in

Reader Support Tickets
Virtual Machine Operator

Custom

Contributor

```
"Actions": [
  "*"
],
"NotActions": [
  "Authorization/*/Delete",
  "Authorization/*/Write",
  "Authorization/elevateAccess/Action"
],
"DataActions": [],
"NotDataActions": [],
"AssignableScopes": [
  "/"
]
```



Role Definition

Three most common roles are:

Owner

Can manage everything, including access

Contributor

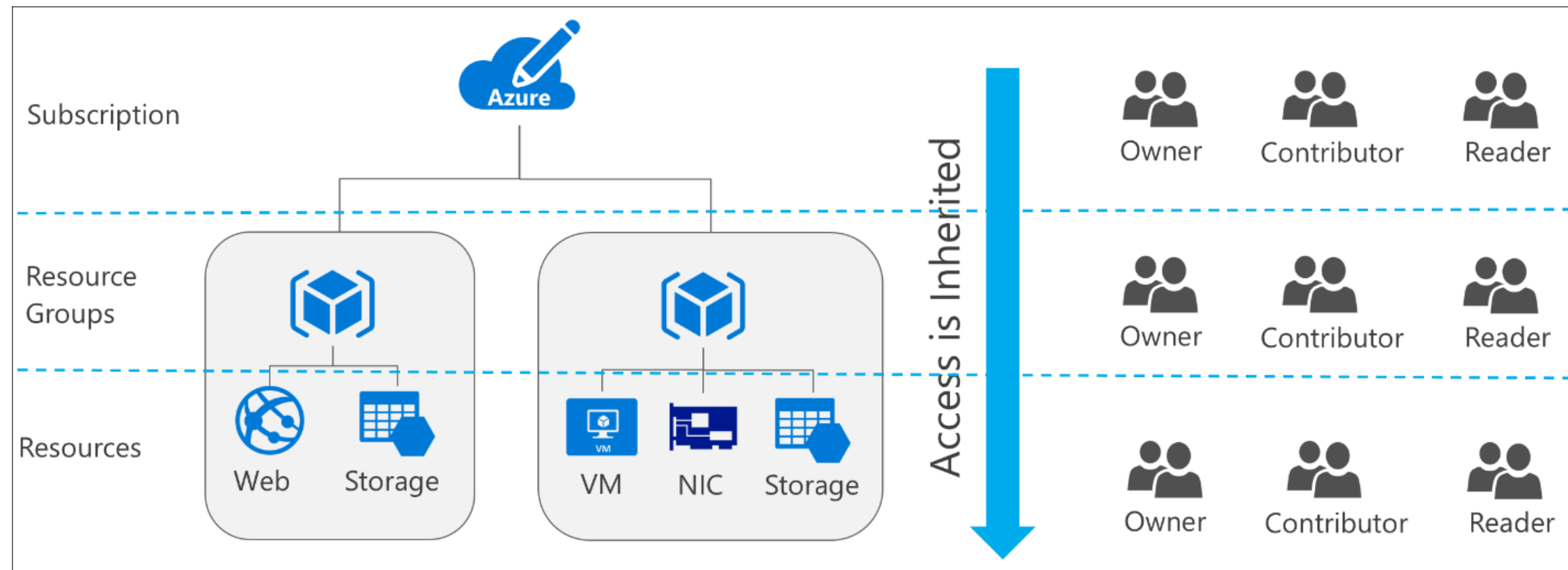
Can manage everything except access

Reader

Can view everything but cannot make changes

Scope

It is the set of Azure resources to which access applies.



A user can limit scope to the four following levels: management group, subscription, resource group, and specific resources.

Managed Identity

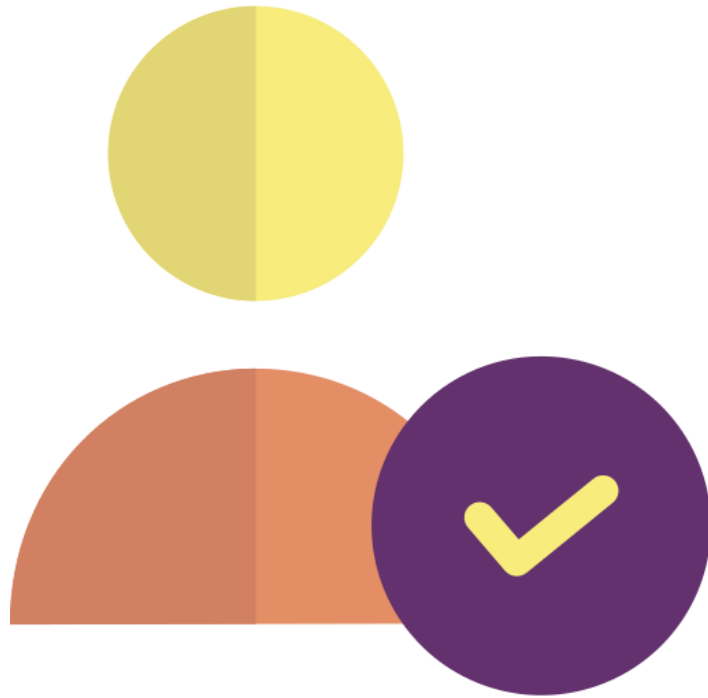
It is an Azure Active Directory service principal.



It is automatically managed by Azure and can be used to authenticate and authorize resource-level operations without the need for explicit credentials or the management of secrets.

Role Assignment

A role assignment is established, linking a security principal to a role.



The security principal defines the access policy and permissions for the user or application in the Entra ID tenant.

Role Assignment

Roles can be assigned to the following types of Entra ID security principals:

Users

Group

Service principals

- Are assigned to organizational users in the AD associated with the subscription
- Can also be assigned to external Microsoft accounts in the same directory

Role Assignment

Roles can be assigned to the following types of Entra ID security principals:

Users

Group

Service principals

- Is assigned to Entra ID security groups
- Is the best practice to manage access through groups, adding roles, and assigning users

Role Assignment

Roles can be assigned to the following types of Entra ID security principals:

Users

Group

Service principals

- Are represented as service principals in the directory
- Authenticate with Entra ID and securely communicate with one another

Microsoft Entra Privileged Identity Management

It helps minimize account privileges by:

Identifying and managing users assigned to administrative roles

Recognizing and removing underutilized or excessively privileged positions

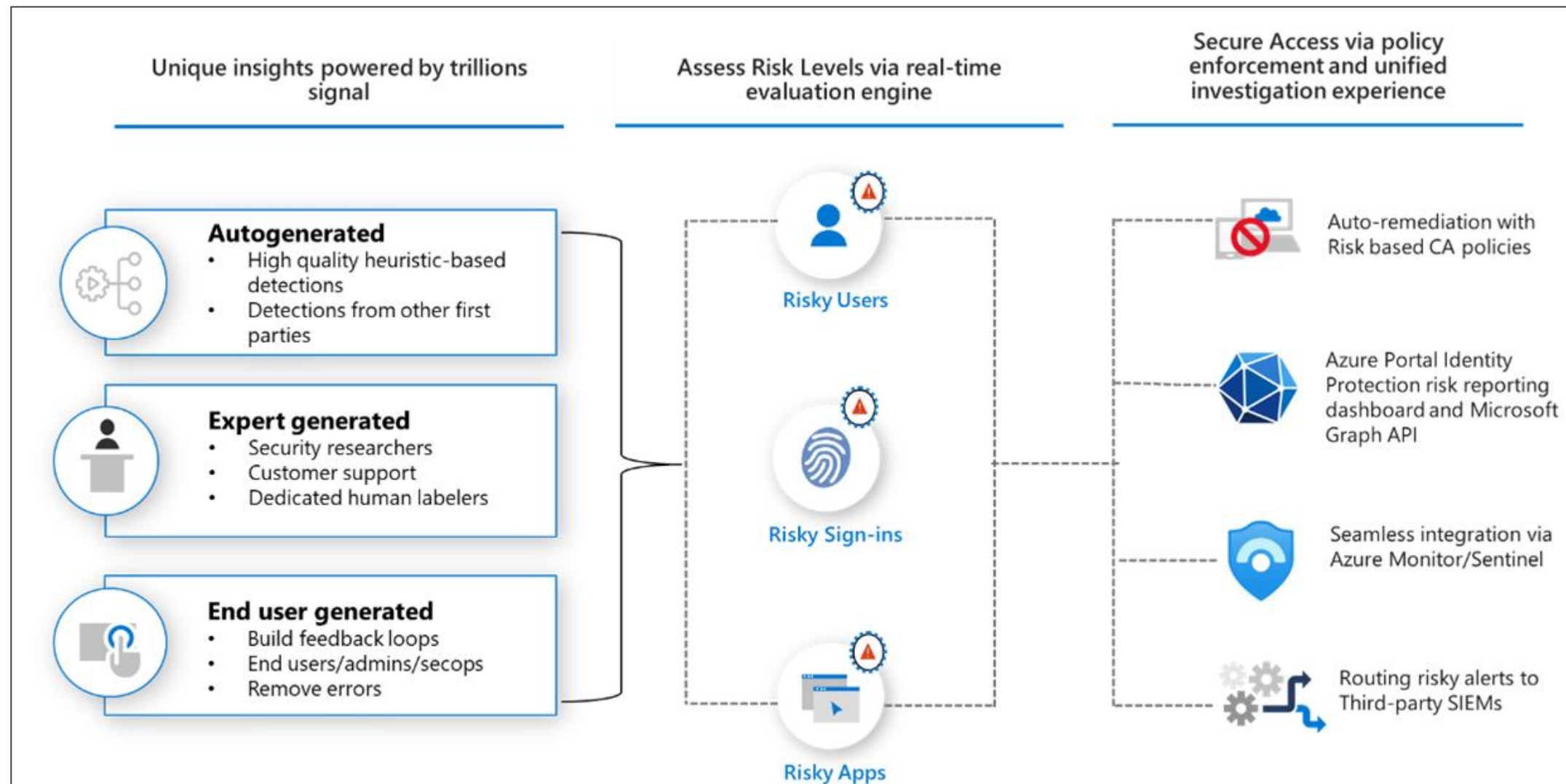
Implementing rules to ensure that privileged roles are granted only for the necessary duration of the task

Implementing rules to ensure that privileged roles are secured through multi-factor authentication



Microsoft Entra ID Protection

The following is an overview of Microsoft Entra ID Protection:



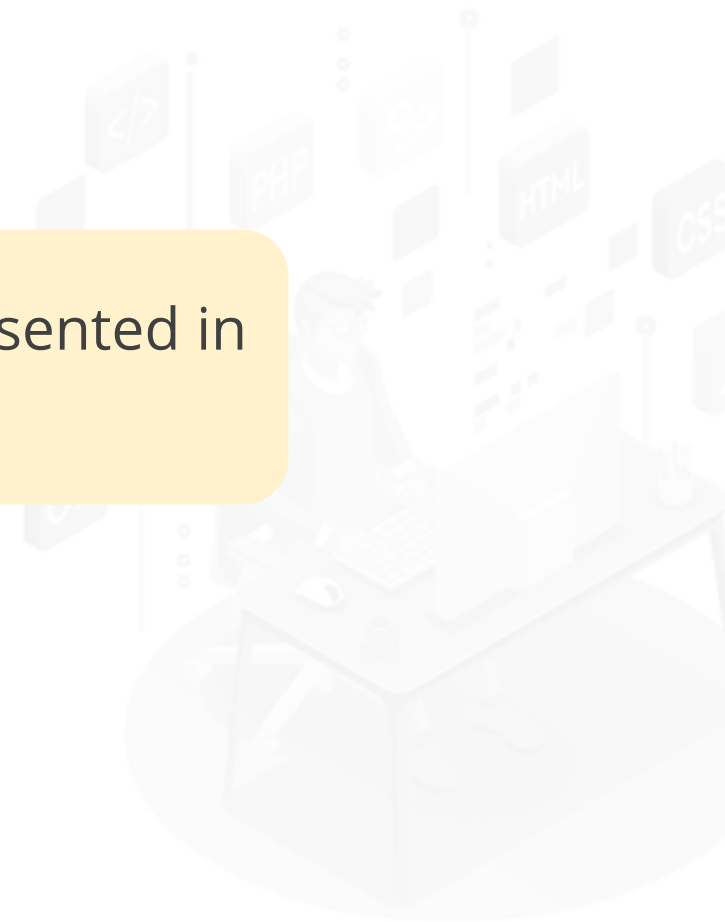
Microsoft Entra ID Protection

It enables organizations to achieve the following key tasks by sending data to SIEM (Security Information and Event Management):

Automate the detection and remediation of identity-based risks

Investigate risks using data presented in the Azure portal

Export risk detection data to third-party utilities for further analysis



Microsoft Entra ID Protection

Risk detection and remediation are given in the table below:

Risk detection type	Description
Atypical travel	Sign in from an atypical location based on the user's recent sign-ins
Anonymous IP address	Sign in from an anonymous IP address (for example: Tor browser or anonymizer VPNs)
Unfamiliar sign-in properties	Sign in with properties we have not seen recently for the given user
Malware linked IP address	Sign in from a malware-linked IP address
Leaked credentials	This risk detection indicates that the user's valid credentials have been leaked
Entra ID threat intelligence	Microsoft's internal and external threat intelligence sources have identified a known attack pattern

Microsoft Entra ID Protection

Key reports that administrators use for investigations into identity protection are:

Risky sign-ins

Risky users

Risk detections

Administrators can review detections and take manual action on them if needed.



Identity and Access Management Best Practices

- Establish a single enterprise directory
- Synchronize identity systems
- Use a cloud provider identity source for third parties
- Implement passwordless or multi-factor authentication for administrators
- Block legacy authentication
- Avoid synchronizing on-premises admin accounts with cloud identity providers
- Utilize modern password protection offerings
- Adopt cross-platform credential management



Implementing Microsoft Entra ID Protection



Duration: 10 Min.

Problem Statement:

You have been asked to demonstrate Microsoft Entra ID features for protection and showcase its capabilities in safeguarding sensitive data.

Outcome:

You will be able to demonstrate the premium features of Microsoft Entra ID for identity protection, showcasing how to configure and manage these features effectively to enhance security and mitigate risks associated with user sign-ins.

Note: Refer to the demo document for detailed steps:
01_Implementing_Microsoft_Entra ID_Protection

ASSISTED PRACTICE

Assisted Practice: Guidelines

Steps to demonstrate the features of identity protection are:

1. Deploy a virtual machine using an Azure resource manager template
2. Implement Microsoft Entra ID Protection
3. Validate the Microsoft Entra ID Protection configuration by simulating risk events



Monitoring Microsoft Entra ID Privileged Identity Management



Duration: 10 Min.

Problem Statement:

You have been asked to monitor and manage Microsoft Entra ID Privileged Identity Management for controlling and overseeing elevated access and permissions within the organization.

Outcome:

You will be able to create and manage privileged identity management (PIM) roles, discover resources, and effectively utilize Microsoft Entra ID PIM to enhance security and control access within your organization.

Note: Refer to the demo document for detailed steps:
02_Monitoring_Microsoft_Entra_ID_Privileged_Identity_Management

ASSISTED PRACTICE

Assisted Practice: Guidelines

Steps to demonstrate Microsoft Entra ID PIM are:

1. Manage resources



Key Takeaways

- The Microsoft identity platform implements the OAuth 2.0 protocol for handling authorization.
- OpenID Connect is a cross-platform authentication system based on the OAuth 2.0 standard family.
- The resource group stores metadata about the resources.
- RBAC provides fine-grained access management of resources in Azure.
- To create a role assignment in RBAC, three elements are required, namely security principal, role definition, and scope.





Knowledge Check

Knowledge Check

01

What are the facts about management groups?

- A. Multiple hierarchy
- B. 7 Levels (including root)
- C. Supports 10,000 subscriptions
- D. Both B and C



Knowledge Check

01

What are the facts about management groups?

- A. Multiple hierarchy
- B. 7 Levels (including root)
- C. Supports 10,000 subscriptions
- D. Both B and C



The correct answer is **D**

A management group tree can support up to six levels of depth, for a total of seven levels, including the root of the management group. 10,000 management groups can be supported in a single directory.

Knowledge Check

02

Which of these is required to create a role assignment for RBAC?

- A. Security principal
- B. Role definition
- C. Scope
- D. All of these



Knowledge
Check

02

Which of these is required to create a role assignment for RBAC?

- A. Security principal
- B. Role definition
- C. Scope
- D. All of these



The correct answer is **D**

To create a role assignment, three elements are required, namely security principal, role definition, and scope.

**Knowledge
Check**
03

What are the key reports that administrators use for investigations in identity protection?

- A. Risky sign-ins
- B. Risky users
- C. Risk detections
- D. All of the above



**Knowledge
Check
03**

What are the key reports that administrators use for investigations in identity protection?

- A. Risky sign-ins
- B. Risky users
- C. Risk detections
- D. All of the above



The correct answer is **D**

The key reports that administrators use for investigations in identity protection are risky sign-ins, risky users, and risk detections.

**Knowledge
Check**
04

Which protocol does the Microsoft identity platform implement for handling authorization?

- A. OAuth
- B. OAuth 2.0
- C. OpenID Connect
- D. All of the above



**Knowledge
Check**
04

Which protocol does the Microsoft identity platform implement for handling authorization?

- A. OAuth
- B. OAuth 2.0
- C. OpenID Connect
- D. All of the above



The correct answer is **B**

The Microsoft identity platform implements the OAuth 2.0 authorization protocol for handling authorization.

TECHNOLOGY

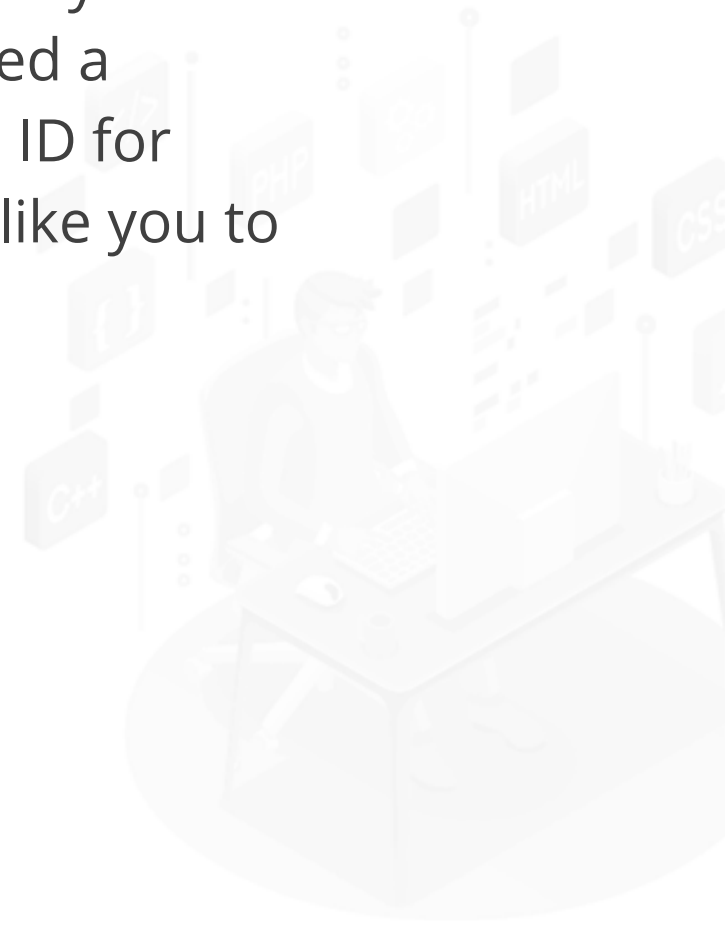


Case Study

Design for Authentication and Authorization Solutions

Scenario

Tailwind Traders is doing well and is expanding their workforce. They have successfully acquired an online retailer in the sports apparel space. The company has also located a partner to outsource marketing literature. Tailwind Traders is using Microsoft Entra ID for user and group accounts. Here are two specific initiatives the IT department would like you to help with:



Design for Authentication and Authorization Solutions

Scenario

New user accounts:

- The online retailer acquisition will add 75 employees to Tailwind Traders. All the new users have on-premises Active Directory Domain Services accounts in the retailer's existing domain.
- The new marketing partner will initially have 15 employees who will need corporate access. These employees already have Microsoft Entra identities in the partner's Microsoft Entra tenant.
- The new employees are located at various geographic locations and need account privileges for their new job roles. Some changes to existing employee roles are expected.
- The IT department wants to take this opportunity to include new identity security features.

Design for Authentication and Authorization Solutions

Scenario

New application access:

- The business development team has an application running on an Azure VM and data stored in an Azure SQL database. They need to securely allow the VM to query the Azure SQL database.
- They also need an on-premises server to be able to securely access the SQL database without storing credentials in the application code or configuration files.

Design for Authentication and Authorization Solutions

Requirements

New user accounts:

- Diagram the process for bringing in the acquired user accounts.
- Diagram the process for adding the new partner accounts.
- For the above requirements, include any tools that will be used. List at least three benefits of your suggested solution.
- Provide at least three recommendations for improving Tailwind Traders' user identity solutions. Rank the recommendations in order of importance. Include your reasons for making these suggestions.

Design for Authentication and Authorization Solutions

Requirements

New application access:

- Provide an access solution for the business development application.
- Provide an access solution for the on-premises resources.

How are you incorporating the well-architected framework pillars to produce a high-quality, stable, and efficient cloud architecture?

Designing Role-Based Access Control

Duration: 10 min



Project Agenda: To implement role-based access control

Description: You are working as the head of cloud security in an organization. You have been given a project to design authorization as part of cloud resource compliance and security. You have been asked to restrict access to different scopes depending on the employee's designation and role and to ensure you follow the principle of least privilege.

LESSON-END PROJECT

Designing Role-Based Access Control

Duration: 10 min

Perform the following:

1. Create two resource groups in two different regions
2. Create two groups under two resource groups in Entra ID
3. Create two users and add them to each of the resource groups in Entra ID
4. Grant contributor access and security assessment contributor access to the DEVELOPMENT group and SECURITY ANALYST group

